

A17. Pràctica: Certificats digitals X.509 amb OpenSSL

0226. Seguretat informàtica

GRUP: SMX2C

RA4. Assegura la privacitat i autenticitat de les comunicacions mitjançant tècniques de signatura digital i certificats, descrivint els elements que hi intervenen.

NOM I COGNOMS: Posa el teu nom i cognoms.

DATA: Escriu la data.

Enunciat de l'activitat:

Aquesta activitat es ceneix a l'apartat NF5-AA3 (Signatura digital) del RA4: signatura digital vs. electrònica, certificats X.509, autoritats de certificació (CA) i els tres nivells legals de signatura electrònica (eIDAS).

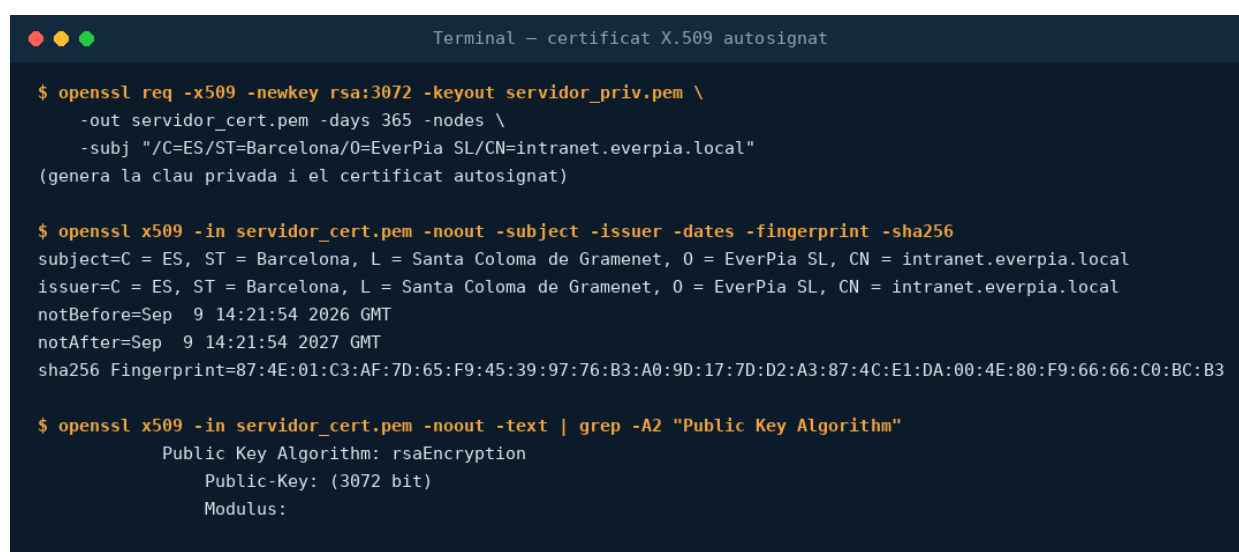
Part 1 · Generació d'un certificat X.509 autosignat

Pas 1. Genera, en una sola ordre, una clau privada RSA i un certificat X.509 autosignat per a un servidor intern (per exemple, la intranet d'una empresa fictícia):

```
$ openssl req -x509 -newkey rsa:3072 \
  -keyout servidor_priv.pem -out servidor_cert.pem \
  -days 365 -nodes \
  -subj "/C=ES/ST=Barcelona/O=EverPia SL/CN=intranet.everpia.local"
```

Pas 2. Inspecciona el certificat generat: subjecte, emissor, dates de validesa i empremta digital (fingerprint):

```
$ openssl x509 -in servidor_cert.pem -noout \
  -subject -issuer -dates -fingerprint -sha256
```



```
Terminal - certificat X.509 autosignat

$ openssl req -x509 -newkey rsa:3072 -keyout servidor_priv.pem \
  -out servidor_cert.pem -days 365 -nodes \
  -subj "/C=ES/ST=Barcelona/O=EverPia SL/CN=intranet.everpia.local"
(genera la clau privada i el certificat autosignat)

$ openssl x509 -in servidor_cert.pem -noout -subject -issuer -dates -fingerprint -sha256
subject=C = ES, ST = Barcelona, L = Santa Coloma de Gramenet, O = EverPia SL, CN = intranet.everpia.local
issuer=C = ES, ST = Barcelona, L = Santa Coloma de Gramenet, O = EverPia SL, CN = intranet.everpia.local
notBefore=Sep  9 14:21:54 2026 GMT
notAfter=Sep  9 14:21:54 2027 GMT
sha256 Fingerprint=87:4E:01:C3:AF:7D:65:F9:45:39:97:76:B3:A0:9D:17:7D:D2:A3:87:4C:E1:DA:00:4E:80:F9:66:66:C0:BC:B3

$ openssl x509 -in servidor_cert.pem -noout -text | grep -A2 "Public Key Algorithm"
    Public Key Algorithm: rsaEncryption
    Public-Key: (3072 bit)
    Modulus:
```

Captura real: generació d'una clau RSA de 3072 bits i un certificat X.509 autosignat, i inspecció de les seves dades principals (subjecte, emissor, validesa i empremta SHA-256).

Reprodueix aquest experiment amb les teves pròpies dades (per exemple, amb el nom d'una empresa fictícia) [CAPTURA] i respon: a) Compara els camps "subject=" i "issuer=" del teu certificat: què hi observes, i què vol dir que coincideixin? b) És aquest certificat vàlid per a un lloc web PÚBLIC d'Internet (per exemple, la botiga en línia d'una empresa real)? Per què? c) Per a quin tipus d'ús SÍ seria adequat un certificat autosignat com aquest?

Part 2 · Del certificat autosignat a un certificat "de veritat"

Respon, relacionant-ho amb la teoria: a) Si volguessis que el certificat de la Part 1 fos reconegut automàticament per qualsevol navegador, sense mostrar cap avís de "connexió no segura", quins passos hauries de seguir (relaciona-ho amb el concepte de CA i de model jeràrquic Root CA → CA Intermèdia)? b) Investiga un

proveïdor real de certificats gratuïts per a llocs web (per exemple, Let's Encrypt) i explica breument com verifica la identitat del sol·licitant abans d'emetre el certificat (rol de la RA).

Part 3 · Signatura electrònica: quin nivell necessito?

Per a cadascun dels següents casos, indica quin dels tres nivells d'eIDAS (simple, avançada o qualificada) recomanaries, i justifica la resposta amb un argument tècnic o legal: a) Acceptar les condicions d'ús d'una aplicació mòbil de música. b) Signar un contracte de lloguer d'un pis des del mòbil, rebent un codi SMS de verificació. c) Presentar la declaració de la renda a l'Agència Tributària. d) Signar internament un document intern de l'empresa que no té cap valor legal fora de l'organització.

Cas pràctic final

Una assessoria fiscal vol començar a signar digitalment els informes que envia als seus 200 clients, per garantir-los que el document no ha estat alterat i que prové realment de l'assessoria. Elabora un informe tècnic que reculli: 1) quin tipus de certificat (autosignat o emès per una CA reconeguda) recomanaries, i per què, tenint en compte que els documents han de ser vàlids fora de l'organització; 2) quin nivell de signatura electrònica (eIDAS) seria l'adequat per a aquest ús; 3) quines mesures prendries per protegir la clau privada de l'assessoria (relaciona-ho amb el que vau veure sobre atacs a la identitat); 4) com explicaries a un client, sense tecnicismes, que la signatura digital li garanteix que el document no ha estat modificat.

Fonts: *Repositori "Materials" (GitHub, SMX-0226SI), NF5/AA3-SignaturaDigital.md (CC-BY-SA-4.0); Reglament eIDAS (UE) 910/2014; Signicat, "Electronic signature: what is it and how to use it"; OpenSSL (openssl.org).*